

Theory of Protection

Confidentiality, **Integrity**, and **Availability** are at the heart of every Infosec practitioner's role. Without maintaining a balance between them, we cannot ensure the safety and security of our enterprises. We keep this balance by ensuring we audit and account (Accounting) for each file, object, and host in our environment; by validating users have correct permissions (Authorization) to view and utilize those items; and ensuring that each user's identity is validated (Authentication) before granting them access to any enterprise resources. Most breaches can be tied back to losing one of those three tenets. This module will focus on attacking and bypassing the tenet of **Authentication** by compromising user passwords in many different operating systems, applications, and encryption types. Let's take a second to discuss authentication and its components in a bit more detail before diving into the exciting part, **attacking passwords**.

Authentication

Authentication, at its core, is the validation of your identity by presenting a combination of three main factors to a validation mechanism. They are;

1. Something you know (a password, passcode, pin, etc.).
2. Something you have (an ID Card, security key, or other MFA tools).
3. Something you are (your physical self, username, email address, or other identifiers.)

The process can require any or all of these authentication descriptors. These methods will be determined based on the severity of the information or systems accessed and how much protection they need. For example, doctors are often required to utilize a Common Access Card (CAC) paired with a pin-code or password to access any terminals that input or store patient data. Depending on the maturity of the organization's security posture, they could require all three types (A CAC, password, and pin from an authenticator app, for example).

Another simple example of this is access to our email address. The proof of information, in this case, would be the knowledge of the email address itself and the associated password. For example, a cell phone with **2FA** can be used. The third aspect can also play a role: the user's presence through biometric recognition such as a fingerprint or facial recognition.

In the previous example, the password is the authentication identifier that can be bypassed with different TTPs. This level is about authenticating the identity. Usually, only the owner and authenticating authority know the password. Authorization is carried out if the correct password is given to the authentication authority. Authorization, in this case, is the set of permissions that the user is granted upon successful login.

The Use of Passwords

The most common and widely used authentication method is still the use of passwords, but what is a password? A password or passphrase can be generally defined as **a combination of letters, numbers, and symbols in a string for identity validation**. For example, if we work with passwords and take a standard 8-digit password that consists only of upper case letters and numbers, we would get a total of **36⁸ (208,827,064,576)** different combinations of passwords.

Realistically, it doesn't need to be a combination of those things. It could be a lyric from a song or poem, a line from a book, a phrase you can remember, or even randomly generated words concatenated together like "TreeDogEvilElephant." The key is for it to meet or exceed the security standards in place by your organization. Using multiple layers to establish identity can make the entire authentication process complicated and costly. Adding complexity to the authentication process creates further effort that can add to

the stresses and workload a person may have during a typical workday. Complex systems can often require inconvenient manual processes or additional steps that could significantly complicate the interaction and **user experience (UX)**. Consider the process of shopping at an online store. Creating an account on the store website can make the authentication and checkout processes much faster than manually inputting your personal information each time you wish to make a purchase. For this reason, using a username and password to secure an account is the most widespread method of authentication that we will see again and again while keeping in mind this balance of convenience and security.

PandaSecurity has compiled **statistics** on various aspects of passwords that give us a good overview of how and in what way passwords are used worldwide. Of interesting to us would be the entry describing **24% of Americans** have used passwords like **password**, **Qwerty**, or **123456**. So, in theory, we could successfully compromise systems using these three passwords at many different organizations due to their widespread use.

Another interesting **statistic** was created by Google. This statistic shows us, for example, other passwords used by 24% of Americans. We can also see that **22%** used their **name**, and **33%** used the name of their **pet** or **children**. Another critical statistic for us is the **password re-use** of an already used password for more than one account, **66%**. This means that 66% of all Americans, according to this statistic, have used the same password for multiple platforms. Therefore, once we have obtained or guessed a password, there is a 66% chance that we could use it to authenticate ourselves on other platforms with the user's ID (username or email address). This would, of course, require that we are able to guess the user's user ID, which, in many cases, is not difficult to do.

One aspect of this statistic that is somewhat more difficult to understand is that only 45% of Americans would change their passwords after a data breach. This, in turn, means that **55% still keep the password** even though it has already been leaked. We can also check if one of our email addresses is affected by various data breaches. One of the best-known sources for this is **HavelBeenPwned**. We enter an email address in the HavelBeenPwned website, and it checks in its database if the email address has already been affected by any reported data breaches. If this is the case, we will see a list of all of the breaches in which our email address appears.

Digging In

Now that we have defined what a password is, how we use them, and common security principles, let's dive into how we store passwords and other credentials.

[Next →](#)

+10 Streak pts

[✔ Mark Complete & Next](#)[📄 Cheat Sheet](#)[📖 Resources](#)

Table of Contents

Introduction

[Theory of Protection](#)

Credential Storage

John The Ripper

Remote Password Attacks

[🔧 Network Services](#)[🔧 Password Mutations](#)[🔧 Password Reuse / Default Passwords](#)

Windows Local Password Attacks

-  Attacking SAM
-  Attacking LSASS
-  Attacking Active Directory & NTDS.dit
-  Credential Hunting in Windows

Linux Local Password Attacks

-  Credential Hunting in Linux
-  Passwd, Shadow & Opasswd

Windows Lateral Movement

-  Pass the Hash (PtH)
-  Pass the Ticket (PtT) from Windows
-  Pass the Ticket (PtT) from Linux

Cracking Files

-  Protected Files
-  Protected Archives

Password Management

- Password Policies
- Password Managers

Skills Assessment

-  Password Attacks Lab - Easy
-  Password Attacks Lab - Medium
-  Password Attacks Lab - Hard

My Workstation

O F F L I N E

 Start Instance

 / 1 spawns left